Click 项目许可证合规分析报告

基于 ScanCode Toolkit 的实际源码扫描

扫描日期 2026 年 10 月 22 日　　项目版本 Click 8.1.7

一 项目介绍与检测范围

本报告选取 GitHub 上 Pallets 社区维护的 Click 项目，使用 ScanCode Toolkit 32.4.1 扫描其固定版本源码，结合文件证据分析许可证识别结果、再分发义务和检测局限。项目声明与许可证文本相互印证；第三方来源代码和未下载依赖仍需单独核查。扫描结果用于形成审查证据，不能自动等同于完整的合规结论。

项目背景与选取理由

Click 是 Python 命令行界面开发工具，提供命令嵌套、参数与选项解析、自动帮助信息等功能，可用于构建脚本和开发工具。项目由 Pallets 社区维护，源码、文档、示例和测试均公开。[1] 选择该项目，是因为代码规模适合在本地完整扫描，同时兼有根许可证、包元数据和第三方代码来源说明，便于比较不同层次的许可证据。

项目	本次固定值
社区与仓库	GitHub / Pallets / pallets/click
版本与提交	8.1.7 874ca2bc1c30d93a4ac6e36a15ed685eafe89097
项目声明	setup.cfg 第 12 行：BSD-3-Clause
实验环境	Windows 11 x64；Python 3.12.14；PowerShell
扫描对象	该提交工作树；Git 跟踪文件 146 个；实际文件记录 144 个

范围与评价口径

本次递归扫描工作树中的源码、文档、示例、测试和配置，排除 .git 版本数据库；工具另默认跳过根目录和 examples/imagepipe 下的两个 .gitignore，实际扫描 144 个文件。没有扫描工具环境，也未下载并扫描运行或开发依赖。固定 8.1.7 用于复现，不表示推荐使用该旧版本。评价分为文本识别一致性、第三方声明充分性及分发义务三个层次。

二 工具选择与安装过程

ScanCode Toolkit 是 AboutCode 生态中的开源扫描工具，能够识别文件中的许可证、版权和软件包信息，并输出机器可读 JSON 与便于阅读的 HTML。选择它的主要原因是能够保留许可证表达式、命中行号和匹配文本，支持从汇总结果追溯原始证据。本次使用 32.4.1，并启用许可、版权、包识别和文件信息扫描。[2]

安装与执行步骤

采用 Python 3.12.14 建立隔离环境，将工具与扫描对象分开。下列命令在作业根目录运行；$py 指向该 Python 解释器。本机由外部 pip 管理尚未带 pip 的虚拟环境。

```
& $py -m venv --without-pip .work/scancode-env
& $py -m pip --python .work/scancode-env/Scripts/python.exe install `
  'scancode-toolkit[full]==32.4.1' 'fingerprints==1.2.3' 'normality==2.6.1' `
  'pluggy==1.5.0' 'click==8.3.0'
$env:SCANCODE_CACHE = Join-Path (Get-Location) '.work/scancode-cache'
$env:SCANCODE_TEMP = Join-Path (Get-Location) '.work/scancode-temp'
.work/scancode-env/Scripts/scancode.exe --version
git clone --depth 1 --branch 8.1.7 https://github.com/pallets/click.git evidence/click-8.1.7
```

执行扫描并将两种原生输出保存到 evidence，完整命令也已写入 rescan.ps1：

```
.work/scancode-env/Scripts/scancode.exe --copyright --license --package `
  --info --license-text --classify --summary --processes 2 --ignore .git `
  --json-pp evidence/scancode-results.json `
  --html evidence/scancode-results.html evidence/click-8.1.7
```

遇到的问题	定位与解决
虚拟环境没有 pip	首次 venv 的 ensurepip 失败，环境仍生成；使用外部 pip 的 --python 参数安装到该环境。
联网安装失败	首次出现本地代理连接 WinError 10013；获得联网执行授权后重试。该网络错误不能解释为软件包版本不存在。
PyICU 构建失败	依赖链 fingerprints → normality 3.x → PyICU 触发编译，缺少 ICU/pkg-config；固定 fingerprints 1.2.3、normality 2.6.1。
启动与缓存问题	pluggy 1.7.0 报缺少插件钩子，改用 1.5.0，并固定工具端 click 8.3.0；默认用户缓存目录不可写，改用工作区缓存。

最终安装版本通过 pip freeze 留档，并使用 pip check 检查依赖一致性。固定间接依赖用于复现实验环境；其他机器应先验证兼容性，不能直接假设所有 Python 版本均可安装。

三 工具输出与检测结果

以下统计均从本次 ScanCode 原始 JSON 提取。HTML 是同一次扫描的原生输出，可按文件查看检测信息；JSON 保留结构化字段、匹配规则及行号。报告内仅摘录核心结果，完整输出随附。

指标	实测结果
工具版本	32.4.1
文件记录数	144
含直接许可证识别的文件	3
未直接识别许可证的文件	141
含版权记录的文件	5
有扫描错误的资源	0
文件级许可证表达式	BSD-3-Clause：3 个文件

许可证证据定位

文件	SPDX 表达式	命中行号与分数
LICENSE.rst	BSD-3-Clause	3-28 / 100.0
setup.cfg	BSD-3-Clause	12-13 / 100.0; 3-28 / 100.0; 22-22 / 99.0
docs/license.rst	BSD-3-Clause	1-1 / 100.0

分数表示某次匹配的文本匹配评分，不是项目整体“合规概率”。同一文件可有多条匹配，因此不能把命中条数与文件数混用；文件没有直接命中，也不表示该文件没有许可或违法。

summary 给出 declared_license_expression=bsd-new、license_clarity_score.score=100；这是许可声明清晰度评分。包版本被静态提取为 attr: click.__version__，并未解析成 8.1.7，因此本报告用 Git 标签、提交及源码版本交叉核对。表中 setup.cfg 的 3-28 行匹配引用 LICENSE.rst，不能当作配置文件自身行号。

原始输出摘录

```
{
  "path": "click-8.1.7/LICENSE.rst",
  "detected_license_expression": "bsd-new",
  "detected_license_expression_spdx": "BSD-3-Clause",
  "scan_errors": []
}
```

核对方法：定位上述文件记录的 license_detections[].matches[]，检查 matched_text、start_line、end_line、score 与 rule_identifier；再回到对应源码行人工复核。包级汇总可能继承或归并许可信息，应与本页“文件直接命中”的统计口径区分。

四 检测结果的详细分析

项目声明与文件证据一致

setup.cfg 第 12 行声明 BSD-3-Clause，根 LICENSE.rst 第 1 行标明 Pallets 版权，第 3 至 28 行给出再分发条件和免责声明；docs/license.rst 引用根许可证。将工具输出与这些文件核对，可以确认主许可声明有实际文本支持。[1][3] 这只能证明已检查证据间没有明显矛盾，不能证明所有下游使用场景都满足条款。

BSD 三条款对使用与分发的影响

依据根许可证和 SPDX 标准文本，BSD-3-Clause 允许在遵守条件的情况下使用、修改及以源码或二进制形式分发。[3] 对源代码再分发，应保留版权声明、条件列表和免责声明；对二进制再分发，应在随附文档或其他材料中提供这些内容；未经许可不能用权利人或贡献者的名称为衍生产品背书。该许可证没有要求所有衍生项目必须公开源码。

因此，若把 Click 打包进应用，不能只写“使用了 Click”或仅保留一个许可证名称。应随产品附带完整许可文本和版权说明，并检查构建流程是否把许可材料从最终安装包中遗漏。仅在网页提供远程链接，未必能确保离线接收者获得所需材料。

第三方来源说明需要独立核查

src/click/parser.py 第 2 至 15 行说明其实现源于 Python 标准库 optparse，第 17 至 23 行保留 Gregory P. Ward 和 Python Software Foundation 的版权记录。该文件不是单纯通过 import 使用标准库，而包含来源于上游的代码，因此需要检查原始许可及通知保留情况。

人工对照 CPython 2.7.18 的 Lib/optparse.py，第 40 至 67 行同时包含上述版权记录及 BSD 三条款式许可。[4] 这说明不能仅凭“Python Software Foundation”名称判为 PSF 许可证，更不能直接宣称与 Click 的 BSD 许可冲突。不过该上游版本仅作为可核查参照，尚未证明它就是 Click 实际复制的版本；应追溯提交历史确认来源及适用许可，再决定补充第三方许可文本。

识别空白与依赖覆盖的解释

两张 examples/imagepipe/example0*.jpg 均检出 Hewlett-Packard 版权，未检出许可。人工检查发现该字串位于嵌入的 sRGB ICC 色彩配置数据中，不能据此认定 HP 是照片作者，也不能直接判定图片侵权；应分别核实图片来源与配置数据的授权。相关字节位置和版权记录已留档。

本次 141 个文件没有直接许可证命中。许多文件依靠项目根许可证说明授权，缺少逐文件声明并不自动构成违规；但第三方复制代码、图片和示例应另行审阅，不能机械继承主许可。setup.py 声明 Windows 条件依赖 colorama 和 Python 低于 3.8 时的 importlib-metadata；包元数据的依赖识别不等于扫描了这些依赖的实际文件。

五 合规建议与实验结论

事项	建议与验收依据
分发通知保留	在安装包或随附文档放置完整 LICENSE.rst，保留 Pallets 版权、三项条件及免责声明；检查最终产物中的实际文件。
parser.py 来源核验	追溯引入提交和上游版本，保留 Ward 与 PSF 版权；核对适用许可全文，必要时加入 THIRD_PARTY_NOTICES。
实际依赖补扫	按目标操作系统与 Python 版本生成并锁定依赖清单，扫描实际下载的 wheel/源码及分发包，汇总其许可和通知。
持续检测	在升级时比较 JSON 的许可证表达式、版权及未知项；由人工确认新增第三方内容和例外，再更新许可清单。

工具质量与本次局限

本次工具的价值在于给出可追溯的文件证据，并将许可证与版权扫描结果分开保存，便于发现仅看项目主页容易忽略的来源问题。安装过程也表明，较完整的扫描工具依赖较多，Windows 下的间接依赖更新可能影响可复现性，因此需要保存工具版本、完整环境清单、命令及失败日志。

本实验只覆盖指定提交的本地文件，不包含未下载依赖、历史提交、发布 wheel 或最终应用分发包；也未检验宣传材料是否存在不当背书。文本匹配可能漏掉隐式授权、非标准声明或无许可头的复制代码，扫描成功和零扫描错误均不能替代完整的法律与分发审查。

结论

在本次固定源码范围内，Click 的主许可证声明与 BSD-3-Clause 文本相符，未从已识别证据中发现明确的许可冲突。可操作的重点是保留完整 BSD 通知、核实 parser.py 的上游来源并补齐必要第三方材料，以及针对真实分发环境补扫依赖。应将结果表述为“限定范围内的证据核查完成，部分分发事项待核验”，不宜写成“工具判定项目完全合规”。

参考资料与随附证据

[1] Pallets Click 8.1.7 源码与 README、setup.cfg、LICENSE.rst。https://github.com/pallets/click/tree/8.1.7

[2] ScanCode Toolkit v32.4.1 发布与安装说明。https://github.com/aboutcode-org/scancode-toolkit/releases/tag/v32.4.1 ；https://github.com/aboutcode-org/scancode-toolkit/blob/develop/INSTALL.rst

[3] SPDX BSD-3-Clause 标准文本。https://spdx.org/licenses/BSD-3-Clause.html

[4] CPython 2.7.18 optparse.py 第 40 至 67 行。https://github.com/python/cpython/blob/v2.7.18/Lib/optparse.py#L40-L67

资料查阅日期：2026-10-22。随附 evidence 目录包括原始 JSON、HTML、扫描日志、安装日志、依赖锁定清单、固定源码及复现说明；附件不属于本文 5 页正文。